REPORT

Information Disclosure

LAB 1: Information disclosure in error messages

Objective: To find sensitive technical information in website error messages by entering unexpected input and checking the error response.

Vulnerability: Information Disclosure

Category: Information Disclosure

Difficulty: Apprentice

Steps:

1. I opened the PortSwigger Web Security Academy and accessed the lab.
2. I opened the lab website in the browser.
3. I selected any product from the shop page.
4. I observed the product URL and its productId parameter.
5. I opened Burp Suite and launched the Burp Browser.
6. I accessed the website and captured the requests using Proxy.
7. I opened HTTP History and selected the product request.
8. I sent the request to Repeater.
9. I changed the productId value by adding a string value “abcd ”.
10. I clicked Send to execute the modified request.
11. I observed that the website displayed an error message.
12. I examined the error message and found the framework version information.
13. I submitted the discovered version information in the lab to complete it.

NIKITA PAWADE INFORMATION DISCLOSURE

Lab: Information disclosure in error messages

APPRENTICE

This lab's verbose error messages reveal that it is using a vulnerable version of a third-party framework. To solve the lab, obtain and submit the version number of this framework.

ACCESS THE LAB

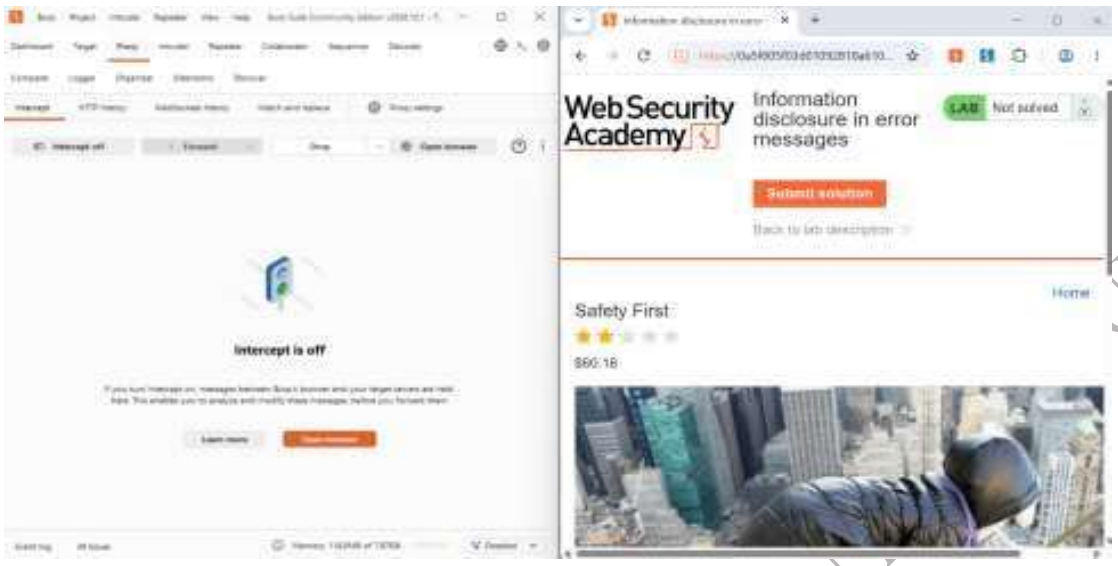
Solution

Community solutions

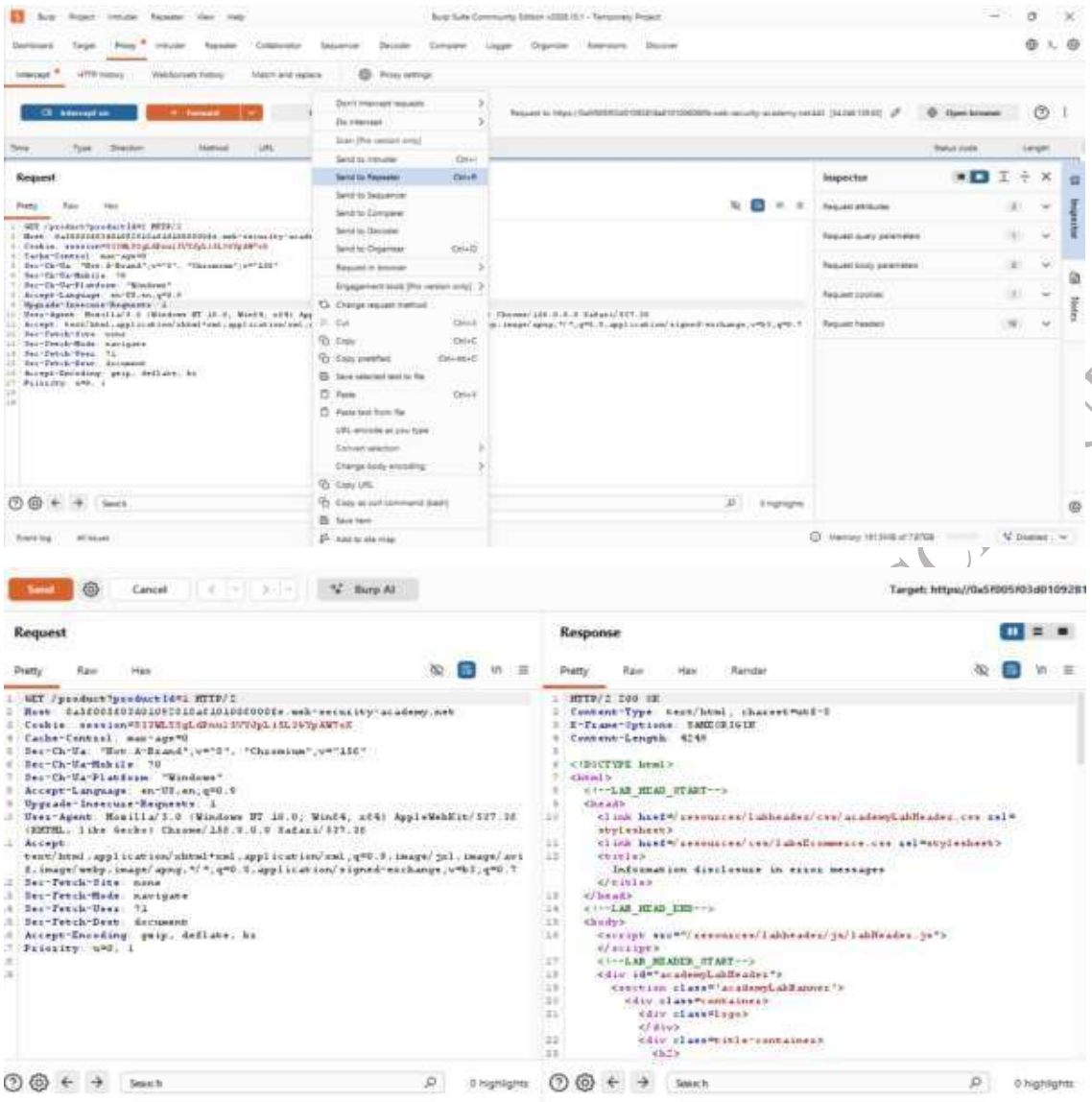




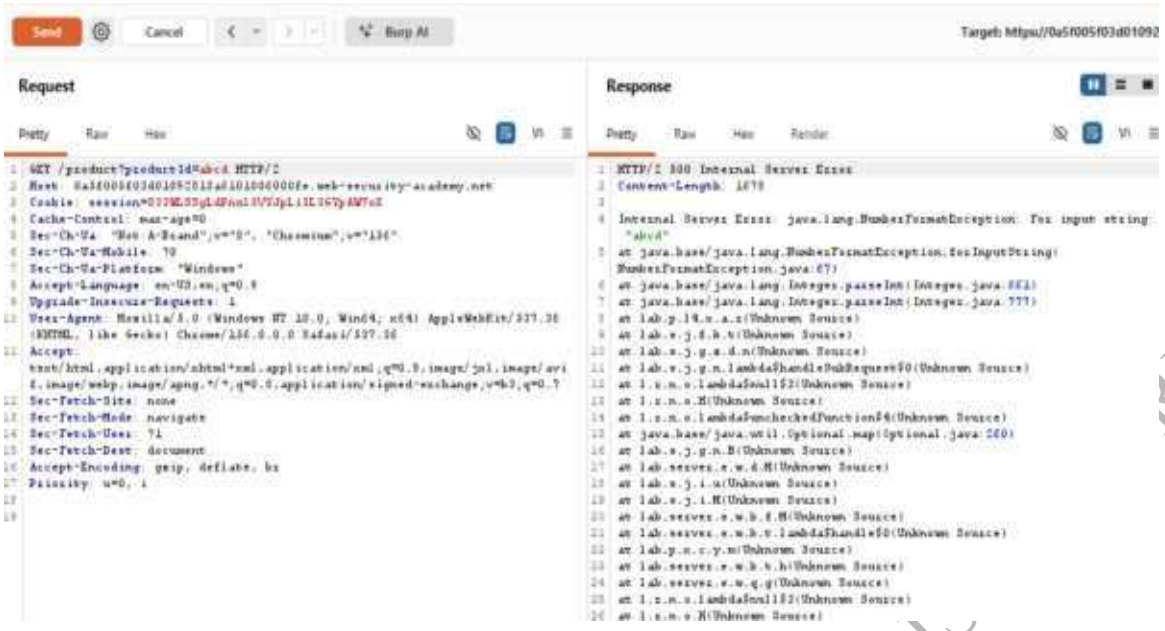




NIKITA PAWADE INFORMATION DISCLOSURE



NIKITA PAWADE




```
35  at lab.t.f.lambda$consume$0(Unknown Source)
36  at java.base/java.util.concurrent.ThreadPoolExecutor.runWorker(
    ThreadPoolExecutor.java:1144)
37  at java.base/java.util.concurrent.ThreadPoolExecutor$Worker.run(
    ThreadPoolExecutor.java:642)
38  at java.base/java.lang.Thread.run(Thread.java:1583)
39
40  Apache Struts 2 2.3.31
```



AI Overview

Apache Struts version 2.3.31 is affected by a critical Remote Code Execution (RCE) vulnerability known as CVE-2017-5638 (also tied to advisories S2-045 and S2-046). Hitachi Global +1

Key Details

- **Vulnerability ID:** CVE-2017-5638 (CVSS Score: 10.0) Tenable
- **Affected Versions:** Apache Struts 2.3.5 through 2.3.31 and Struts 2.5 through 2.5.10 www.trendmicro.com
- **Attack Mechanism:** An unauthenticated remote attacker can inject a malicious OGNL (Object-Graph Navigation Language) expression via the `Content-Type` HTTP header in a `multipart/form-data` file upload request. This allows arbitrary operating system command execution on the server. Exploit-DB +1





Key Learnings:

1. Learned about Information Disclosure vulnerabilities.
2. Understood how error messages can reveal sensitive information.
3. Practiced capturing HTTP requests using Burp Suite.
4. Learned how to modify requests using Repeater.
5. Understood how unexpected input can generate error messages.
6. Learned how framework version details can be exposed.
7. Understood the importance of hiding technical information from users.

NIKITA PAWADE INFORMATION DISCLOSURE

Lab 2: Information Disclosure on Debug Page

Vulnerability: Information Disclosure

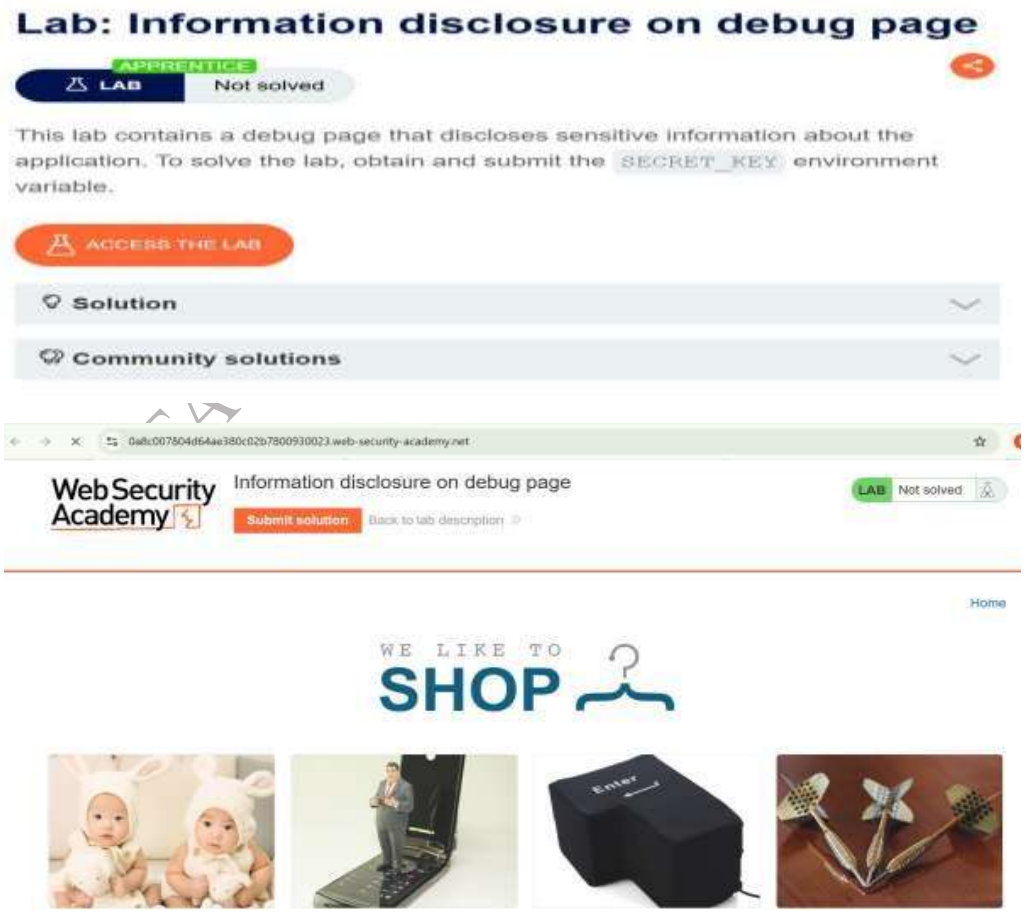
Category: Information Disclosure

Difficulty: Apprentice

Objective: To find a hidden debug page on the website and obtain the SECRET_KEY information exposed on that page.

Steps:

1. I accessed the Information Disclosure on Debug Page lab on PortSwigger.
2. I opened the lab website in the browser.
3. I right-clicked on the webpage and selected View Page Source.
4. I searched for hidden information in the page source.
5. I found a URL path related to the debug page and I copied the URL path and pasted it into the browser's address bar.
6. I opened the debug page and found a PHP information file.
7. I examined the information displayed on the page.
8. I searched for the SECRET_KEY value.
9. I copied the secret key and submitted it in the lab.
10. The lab was successfully completed.



INFORMATION DISCLOSURE

view-source:https://0a8c007804d64ae380c02b7800930023.web-security-academy.net

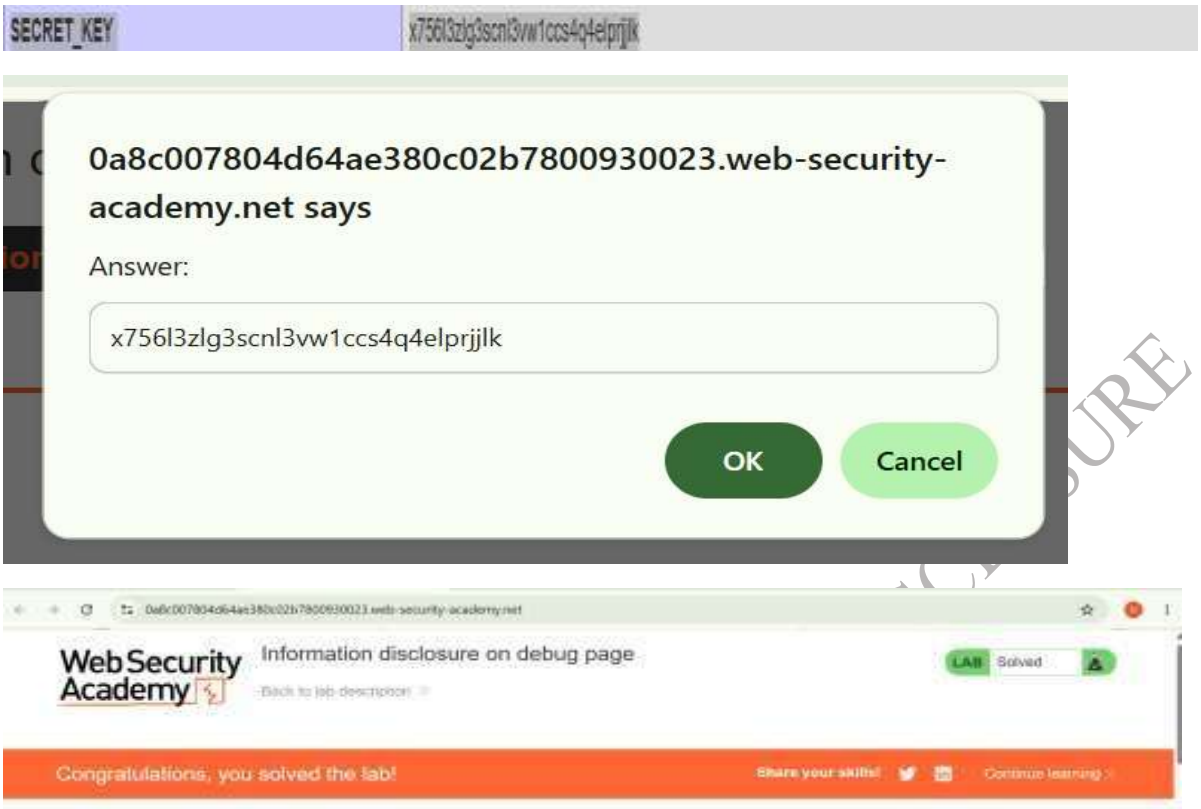
```
                        <a class="button" href="/product?productId=17">View details</a>
                    </div>
                    <div>
                        <img src="/image/productcatalog/products/36.jpg">
                        <h3>Caution Sign</h3>
                        <img src="/resources/images/rating3.png">
                        $44.25
                        <a class="button" href="/product?productId=18">View details</a>
                    </div>
                    <div>
                        <img src="/image/productcatalog/products/64.jpg">
                        <h3>Hexbug Battleground Tarantula Double Pack</h3>
                        <img src="/resources/images/rating3.png">
                        $55.33
                        <a class="button" href="/product?productId=19">View details</a>
                    </div>
                    <div>
                        <img src="/image/productcatalog/products/29.jpg">
                        <h3>Waterproof Tea Bags</h3>
                        <img src="/resources/images/rating4.png">
                        $64.87
                        <a class="button" href="/product?productId=20">View details</a>
                    </div>
                </section>
                <!-- <a href=/cgi-bin/phpinfo.php>Debug</a> -->
            </div>
        </section>
        <div class="footer-wrapper">
        </div>
    </div>
</body>
</html>
```

```
                        $64.87
                        <a class="button" href="/product?productId=20">View details</a>
                    </div>
                </section>
                <!-- <a href=/cgi-bin/phpinfo.php>Debug</a> -->
            </div>
        </section>
        <div class="footer-wrapper">
        </div>
```

0a8c007804d64ae380c02b7800930023.web-security-academy.net/cgi-bin/phpinfo.php

PHP Version 7.4.3-4ubuntu2.29

System	Linux 69d5390b845d 4.14.355-287.755.amzn2.x86_64 #1 SMP Mon Oct 5 20:32:32 UTC 2026 x86_64
Build Date	Mar 25 2025 18:57:03
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/cgi
Loaded Configuration File	/etc/php/7.4/cgi/php.ini
Scan this dir for additional .ini files	/etc/php/7.4/cgi/conf.d
Additional .ini files parsed	/etc/php/7.4/cgi/conf.d/10-opcache.ini, /etc/php/7.4/cgi/conf.d/10-pdo.ini, /etc/php/7.4/cgi/conf.d/15-xml.ini, /etc/php/7.4/cgi/conf.d/20-calendar.ini, /etc/php/7.4/cgi/conf.d/20-ctype.ini, /etc/php/7.4/cgi/conf.d/20-dom.ini, /etc/php/7.4/cgi/conf.d/20-exif.ini, /etc/php/7.4/cgi/conf.d/20-ffi.ini, /etc/php/7.4/cgi/conf.d/20-fileinfo.ini, /etc/php/7.4/cgi/conf.d/20-ftp.ini, /etc/php/7.4/cgi/conf.d/20-gettext.ini, /etc/php/7.4/cgi/conf.d/20-iconv.ini, /etc/php/7.4/cgi/conf.d/20-json.ini, /etc/php/7.4/cgi/conf.d/20-phar.ini, /etc/php/7.4/cgi/conf.d/20-posix.ini, /etc/php/7.4/cgi/conf.d/20-readline.ini, /etc/php/7.4/cgi/conf.d/20-shmop.ini, /etc/php/7.4/cgi/conf.d/20-simplexml.ini, /etc/php/7.4/cgi/conf.d/20-sockets.ini, /etc/php/7.4/cgi/conf.d/20-sysvmsg.ini, /etc/php/7.4/cgi/conf.d/20-sysvsem.ini, /etc/php/7.4/cgi/conf.d/20-sysvshm.ini, /etc/php/7.4/cgi/conf.d/20-tokenizer.ini, /etc/php/7.4/cgi/conf.d/20-xmlreader.ini, /etc/php/7.4/cgi/conf.d/20-xmlwriter.ini, /etc/php/7.4/cgi/conf.d/20-xsl.ini, /etc/php/7.4/cgi/conf.d/99-academy.ini
PHP API	20190902
PHP Extension	20190902
Zend Extension	320190902
Zend Extension Build	API320190902,NTS
PHP Extension Build	API20190902,NTS
Debug Build	no
Thread Safety	disabled



Key Learnings:

1. Learned how to inspect website source code.
2. Understood how hidden URLs can expose sensitive information.
3. Learned how to access publicly exposed debug pages.
4. Understood how PHP information files reveal server details.
5. Learned how sensitive information like secret keys can be exposed.
6. Understood the importance of securing debug files and hidden pages.

NIKITA PAWADE INFORMATION DISCLOSURE

Lab 3 – Source Code Disclosure via Backup Files
Vulnerability: Source Code Disclosure
Category: Information Disclosure
Difficulty: Apprentice
Objective: To find a backup file on the website, access its source code and obtain the database password.
Steps:

1. I accessed the Source Code Disclosure via Backup Files lab on PortSwigger.
2. I opened the lab website in the browser.
3. I added /robots.txt at the end of the website URL.
4. I opened the robots.txt file and checked its contents.
5. I found a hidden /backup directory mentioned in the file.
6. I opened the backup directory using the browser.
7. I found a backup file named ProductTemplate.java.bak.
8. I opened the backup file to view its source code.
9. I searched for the database connection details in the source code.
10. I found the database password written in the file.
11. I copied the password and submitted it in the lab.
12. The lab was successfully completed.



INFORMATION DISCLOSURE






```
User-agent: *
Disallow: /backup
```



Index of /backup

Name	Size
ProductTemplate.java.bak	1647B

```
package data.productcatalog;

import common.db.JdbcConnectionBuilder;

import java.io.IOException;
import java.io.ObjectInputStream;
import java.io.Serializable;
import java.sql.Connection;
import java.sql.ResultSet;
import java.sql.SQLException;
import java.sql.Statement;

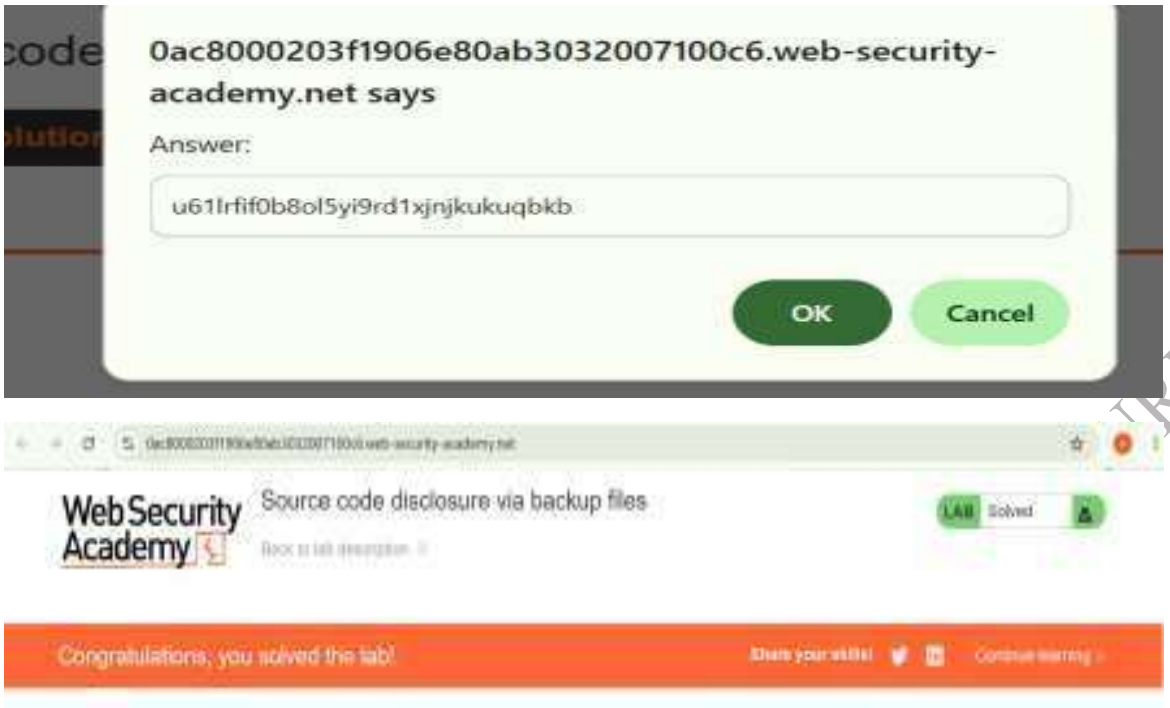
public class ProductTemplate implements Serializable
{
    static final long serialVersionUID = 1L;

    private final String id;
    private transient Product product;

    public ProductTemplate(String id)
    {
        this.id = id;
    }

    private void readObject(ObjectInputStream inputStream) throws IOException, ClassNotFoundException
    {
        inputStream.defaultReadObject();

        ConnectionBuilder connectionBuilder = ConnectionBuilder.from(
                "org.postgresql.Driver",
                "postgresql",
                "localhost",
                5432,
                "postgres",
                "postgres",
                "u61lrfif0b8ol5yi9rd1xjnjkukuqbkb"
        ).withAutoCommit();
        try
```



Key Learnings:

1. Learned about source code disclosure vulnerabilities.
2. Understood the purpose of the robots.txt file.
3. Learned how to find hidden directories on a website.
4. Learned how to identify sensitive information in source code.
5. Understood how database passwords can be exposed.
6. Learned the importance of protecting backup files.

NIKITA PAWADE INFORMATION

Lab 4: Authentication Bypass via Information Disclosure

Vulnerability: Authentication Bypass

Category: Information Disclosure

Difficulty: Apprentice

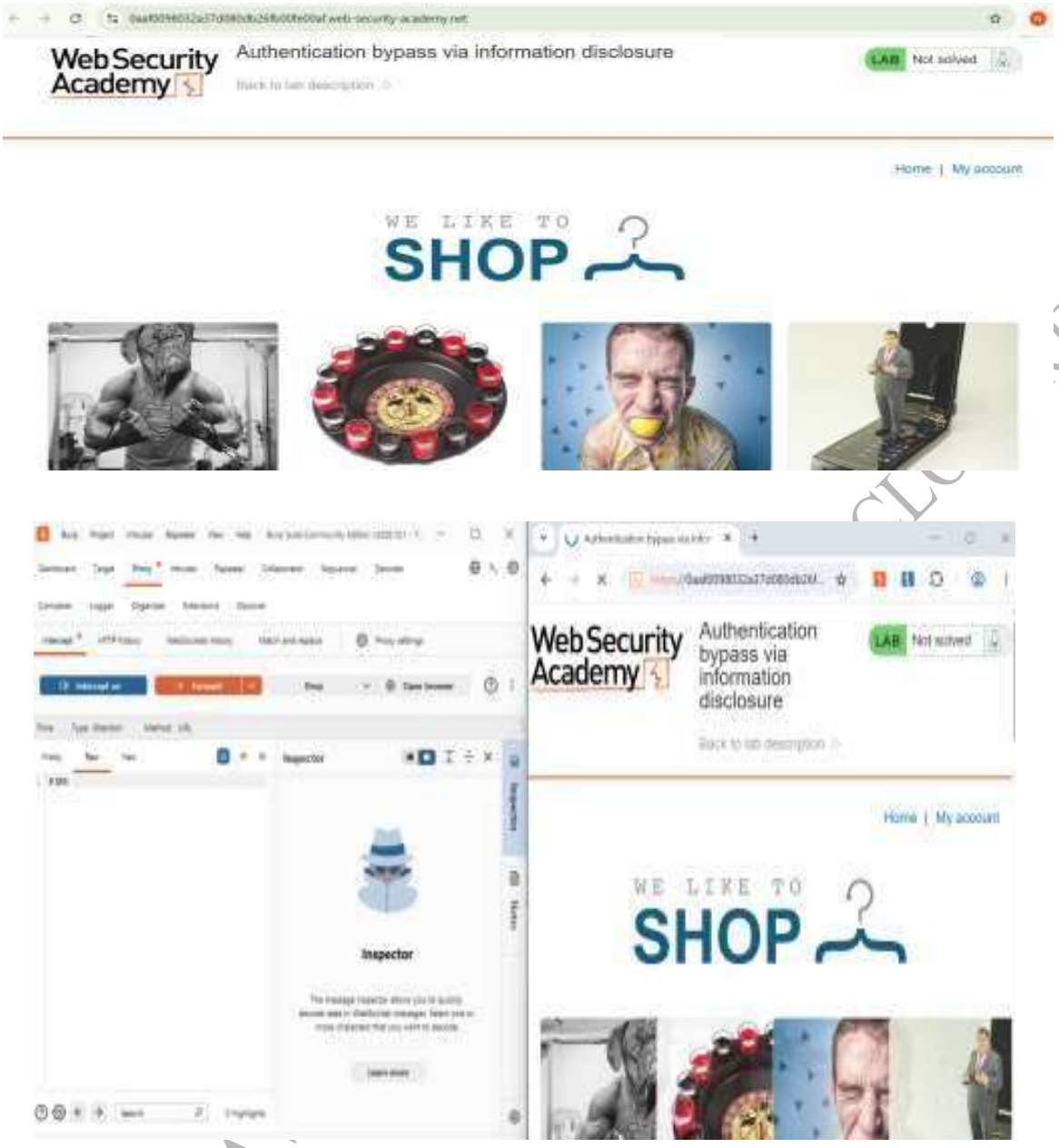
Objective:To bypass the website's authentication by finding sensitive information in the HTTP response and accessing an administrator account.

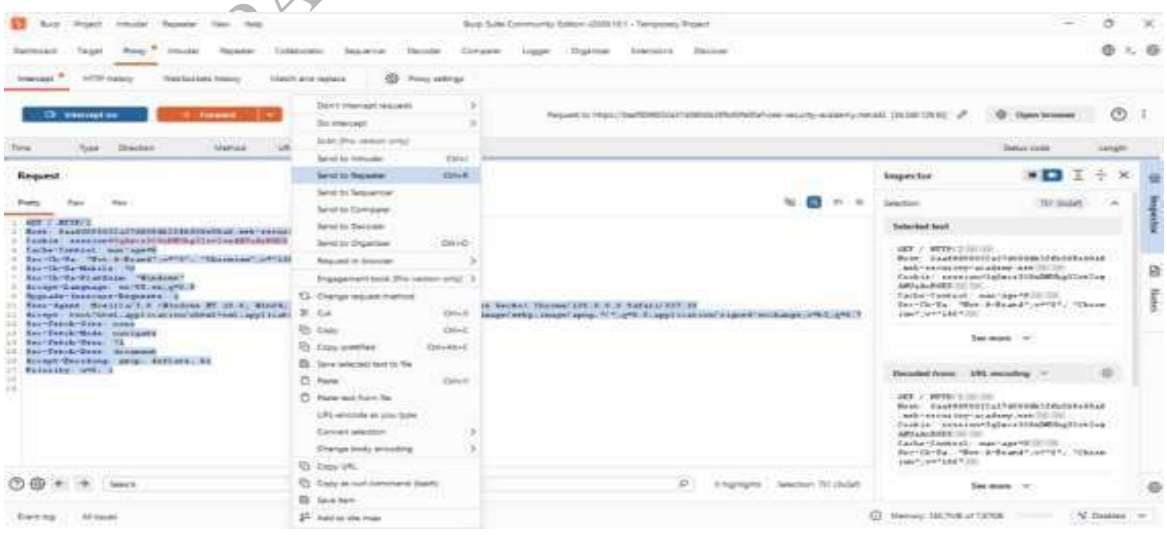
Steps:

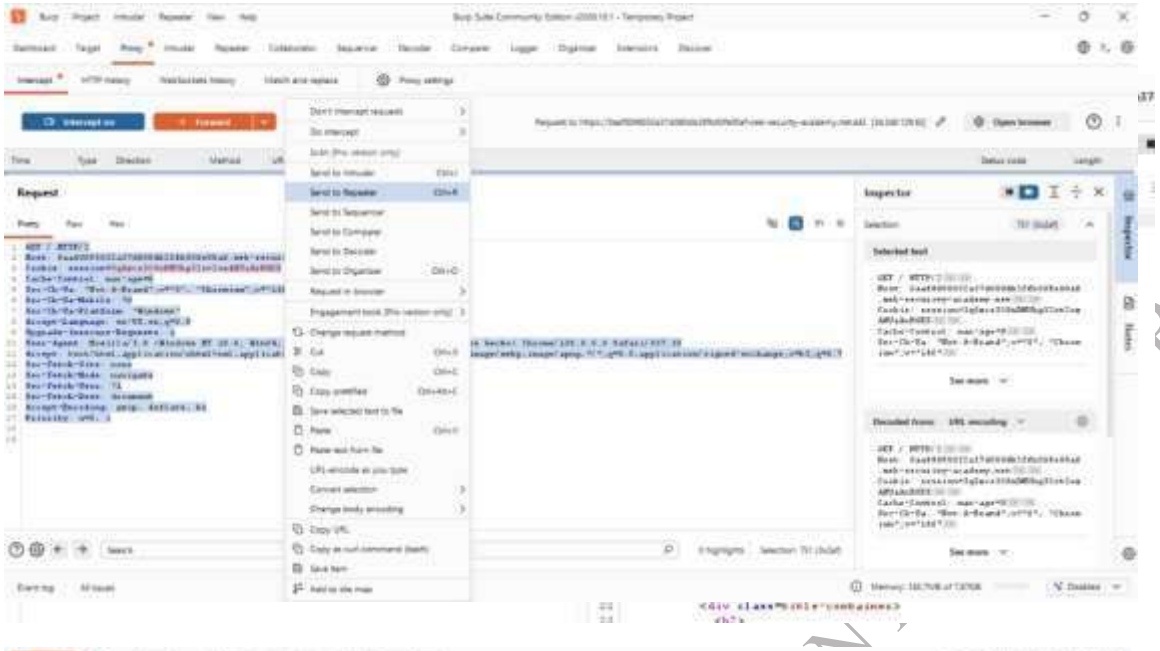
1. I accessed the Authentication Bypass via Information Disclosure lab on PortSwigger.
2. I opened Burp Suite and launched the Burp Browser.
3. I accessed the lab website.
4. I opened the Proxy tab and checked the HTTP History.
5. I selected the request sent to the website.
6. I sent the request to Repeater.
7. I changed the HTTP request method from GET to TRACE.
8. I clicked Send to view the server response.
9. I examined the response and found information about the authentication header.
10. I used the discovered information to understand how the website checks administrator access.
11. I modified the request to access the administrator functionality.
12. I accessed the administrator page and completed the lab.

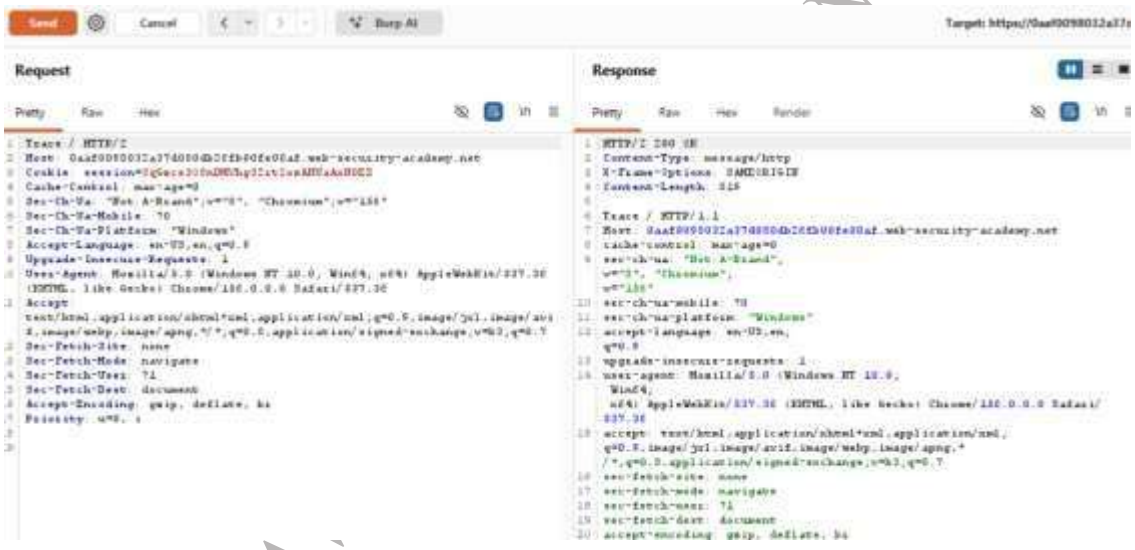


NIKITA PAWADE INFORMATION DISCLOSURE

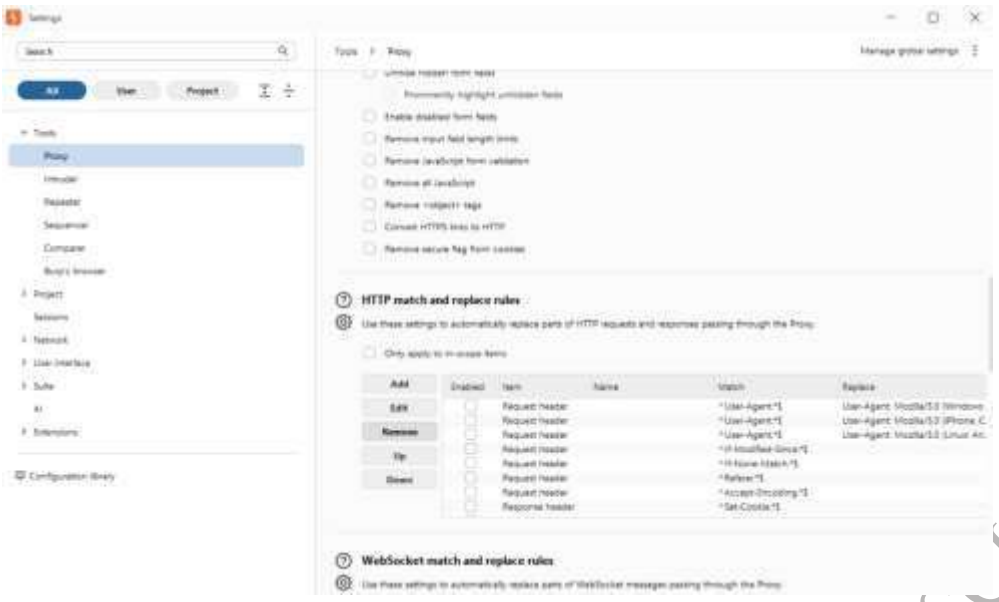

Web Security Academy
Authentication bypass via information disclosure
LAB Not solved
Back to lab description
Home | My account
WE LIKE TO SHOP
Inspector

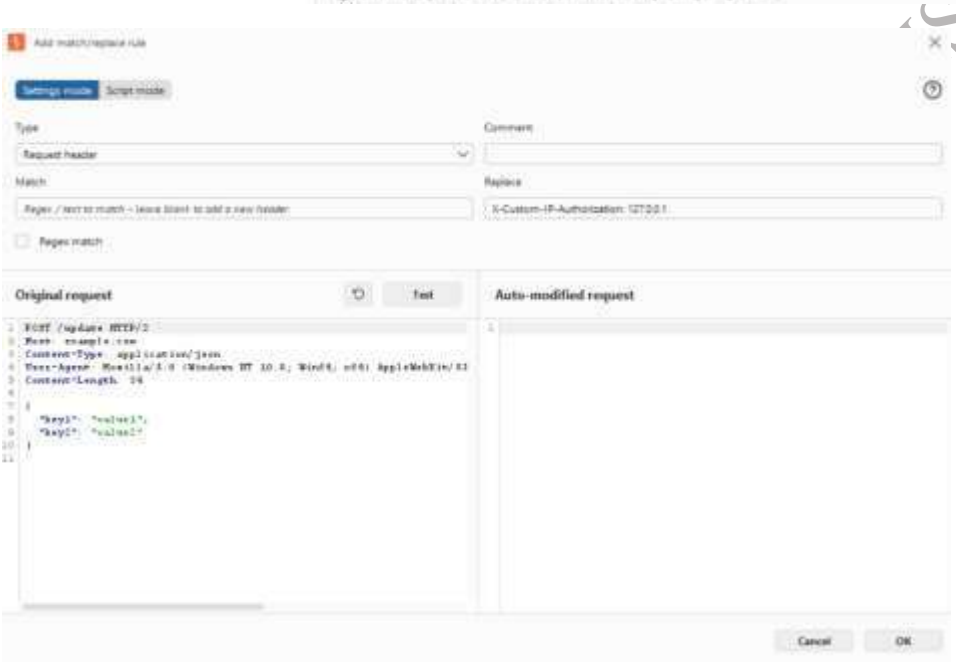


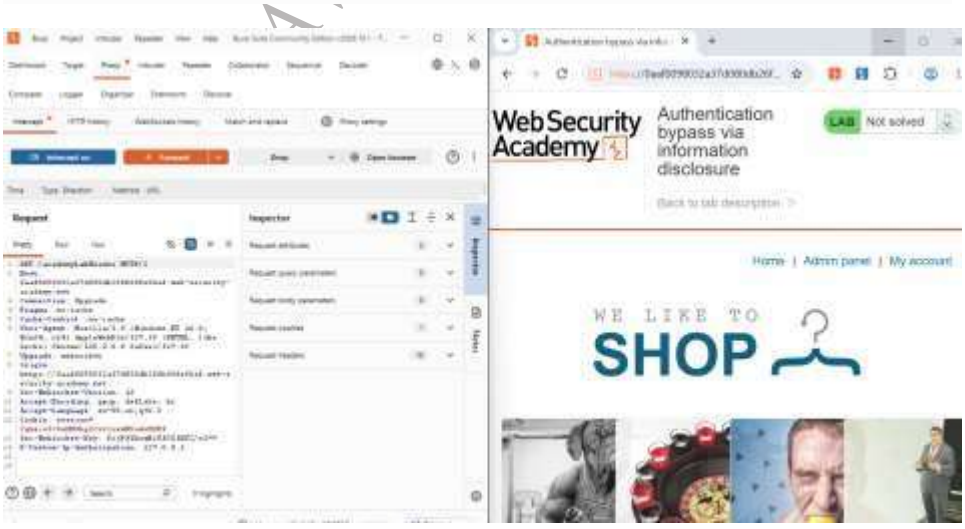




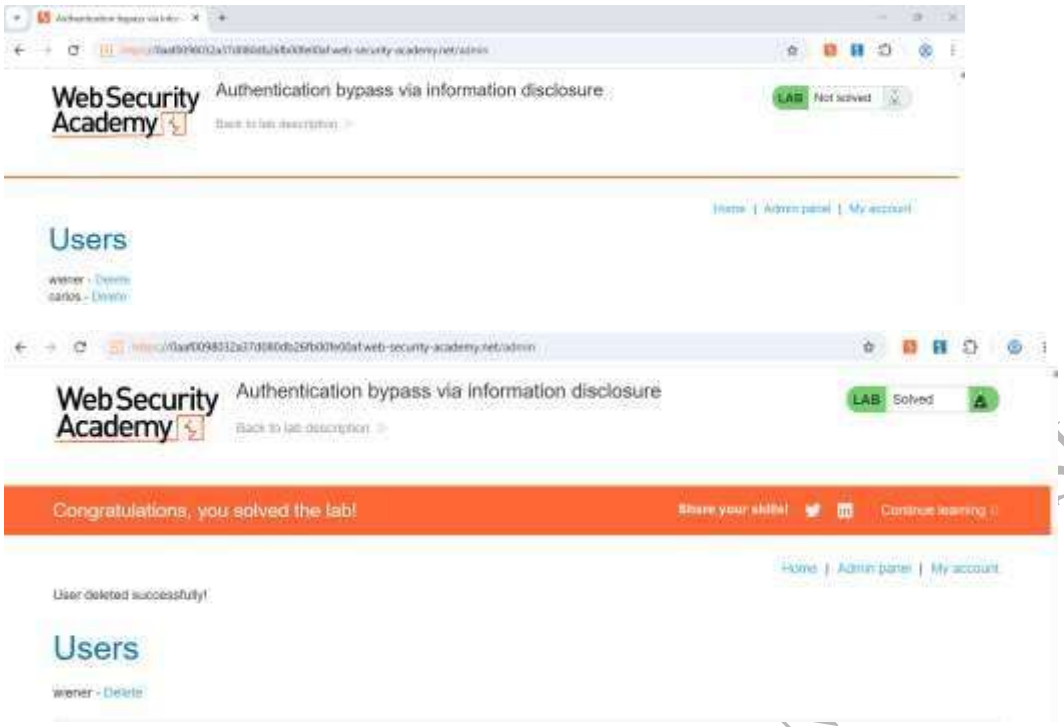
```
16 sec-fetch-site: none
17 sec-fetch-mode: navigate
18 sec-fetch-user: ?1
19 sec-fetch-dest: document
20 accept-encoding: gzip, deflate, br
21 priority: u=0, i
22 cookie: session=3qGsce308nDMVhg32rt2osAHUaAxH0E2
23 Content-Length: 0
24 X-Custom-IP-Authorisation: 223.238.180.95
25
```


HTTP match and replace rules
WebSocket match and replace rules


Original request
Auto-modified request
Cancel
OK


Web Security Academy
Authentication bypass via information disclosure
LAB Not solved
Home | Admin panel | My account
WE LIKE TO SHOP

DISCLOSURE



Key Learnings:

1. Learned about authentication bypass vulnerabilities.
2. Understood how HTTP methods can reveal server information.
3. Learned about the HTTP TRACE method.
4. Practiced capturing requests using Burp Suite.
5. Learned how to modify HTTP requests using Repeater.
6. Learned the importance of securing HTTP methods and authentication checks.

NIKITA PAWADE, INFORMATION DISCLOSURE